

MODULE 04 · DOMAIN 1 - DESIGN SOLUTIONS FOR ORGANIZATIONAL COMPLEXITY

Identity at Scale

Identity Center, federation, and the four directory answers.

DOMAIN 1 of 4 EXAM WEIGHT 26% MODULE 4 of 44

Identity Center does not replace IAM. It replaces **IAM users**. What people receive is still a role.

What actually happens at sign-in

01

Authenticate

The identity source proves who the user is.

02

Look up

Identity Center finds their group assignments.

03

Match

A permission set is assigned to that group for that account.

04

Assume

The user assumes the role the permission set created.

05

Expire

Temporary credentials, which lapse on their own.

ON THE EXAM

A permission set is not a new kind of policy. It is a template that provisions an IAM role into every assigned account.

Facts about Identity Center the exam checks

- ◆ **An organization instance lives in the management account.** One per organisation, with administration delegable.
- ◆ **Account instances** are single-account, for AWS managed applications only. Not for multi-account access.
- ◆ **An instance runs in one Region.** Changing it means rebuilding, so decide early.
- ◆ **SCIM** provisions users and groups automatically. Assign permission sets to **groups**, never to individuals.

ON THE EXAM

Delegated administration moves the day-to-day work out of the management account, which is what module two told you to do.

Three identity sources

SOURCE	USE IT WHEN	THE CATCH
Identity Center directory	No existing corporate directory, or a small organisation	You now run a second user store
Active Directory	Corporate AD already holds the workforce	Needs Managed Microsoft AD or AD Connector underneath
External identity provider	Okta, Entra ID, Ping or similar is already the source of truth	Use SCIM, or provisioning becomes manual

ON THE EXAM

The right answer is almost always whichever directory the company already has. Creating a second source of truth is the anti-pattern.

Managed Microsoft AD or AD Connector?

AWS MANAGED MICROSOFT AD

A real directory running in AWS

- Real Windows Server AD, not an emulation
- Group Policy, schema extensions, trusts
- Shareable across accounts, 25 or 500
- Needed for FSx and RDS for SQL Server

AD CONNECTOR

A proxy to your existing directory

- Stores nothing in AWS
- Your password and lockout policies apply
- Cannot be shared across accounts
- Not multi-VPC aware; fails with the link

THE TIEBREAKER

No directory data may live in AWS means AD Connector. Sharing across accounts, or trusts, means Managed Microsoft AD.

Simple AD, and an honest warning

- ◆ **Samba 4 based**, not real Active Directory. Small up to 500 users, Large up to 5,000.
- ◆ **No trust relationships. No schema extensions. No multi-factor authentication.** Those three absences decide most questions.
- ◆ **Closed to new customers since 30 July 2026.** AWS points at Managed Microsoft AD or AD Connector instead.
- ◆ Still on the in-scope service list, so answer with it if a question describes a small, standalone, low-cost directory.
- ◆ Any mention of a **trust to an existing forest** eliminates it instantly, whatever the budget says.

ON THE EXAM

Teach yourself the examinable answer and know the reality. You cannot buy this today, and it is still a correct exam answer.

Workforce or customers?

IAM IDENTITY CENTER

Your employees

- Hundreds or thousands of people you employ
- They need the console, the CLI and AWS applications
- Access is by job role, managed centrally
- Free of charge

AMAZON COGNITO

Your application's users

- Thousands to millions of people you do not employ
- They need your app, not the AWS console
- Sign-up, sign-in, social and enterprise federation
- Priced per monthly active user

THE TIEBREAKER

Ask who the people are. Employees mean Identity Center. Customers of an application mean Cognito. The scale in the question usually gives it away.

Cognito: two components, two jobs

- ◆ **User pool.** A directory for your application. Sign-up, sign-in, MFA, social and SAML federation. It returns tokens.
- ◆ **Identity pool.** Exchanges a token for **temporary AWS credentials** from an IAM role.
- ◆ User pool answers who are you. Identity pool answers what may you touch in my AWS account.
- ◆ An identity pool can issue credentials to **unauthenticated** guests as well, with a separate, narrower role.
- ◆ If users never touch an AWS service directly, you may need only a user pool.

ON THE EXAM

App users uploading straight to S3 or writing to DynamoDB means an identity pool.
Signing in to your app alone means a user pool.

Thirty teams needing thirty different scopes does not mean thirty permission sets. It means **one**, plus attributes.

Trusted identity propagation

- ◆ **The user's identity travels into the data service**, rather than stopping at the application's role.
- ◆ Without it, CloudTrail records the role that queried the data. Every analyst looks identical in the audit trail.
- ◆ Targets include **Redshift, Athena, EMR, Lake Formation, S3 Access Grants, OpenSearch** and Transfer Family.
- ◆ Permissions are then granted to existing groups, so entitlements live in one place.
- ◆ Requires Identity Center, and an organization instance is recommended.

ON THE EXAM

The audit trail names the role rather than the person is the signature phrase. That is what this feature exists to fix.

Reading the scenario

THE SCENARIO SAYS

Employees need console access across many accounts

No directory data may be stored in AWS

Domain join across several accounts, or a forest trust

Millions of application users signing in

App users must upload directly to S3

Audit shows the role, not the person

IT IS POINTING AT

Identity Center with permission sets

AD Connector

AWS Managed Microsoft AD

Cognito user pool

Cognito identity pool

Trusted identity propagation

ON THE EXAM

Identify who the humans are first. Employee, application user, or a service. That single question eliminates most options.

Meridian Freight has 210 AWS accounts. Engineers currently hold an IAM user in each account they work in, with access keys stored locally. Offboarding takes a week and the security team cannot confirm it is ever complete.

The company already runs Entra ID for all staff. Auditors have asked for a single, provable list of who can reach production.

What should the solutions architect recommend?

- ☐ A A central identity account holding IAM users, with cross-account roles into each account
- ☐ B IAM Identity Center with Entra ID as the identity source, SCIM provisioning, and permission sets assigned to groups
- ☐ C An IAM SAML identity provider configured in each of the 210 accounts, trusting Entra ID
- ☐ D Rotate all IAM user access keys every 30 days using Secrets Manager

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

Central identity account
The pre-Identity Center pattern. Better than today, but it still means IAM users, long-lived keys, and trust policies maintained in 210 places.
- B

Identity Center with Entra ID
Entra ID stays the source of truth, SCIM removes the leaver problem, and permission sets give auditors one place to read.
- C

SAML provider per account
Federation without central management. You would configure and maintain the same trust 210 times, which is the overhead being complained about.
- D

Rotate the keys
Treats a symptom. A rotated key belonging to someone who left last month is still a key belonging to someone who left.

THE SIGNAL

A directory already exists, offboarding is unreliable, and auditors want one list. All three point the same way.

A company has 40 delivery teams sharing several AWS accounts. Each team must administer only the resources it owns, which are tagged with the team name. New teams form roughly monthly.

The platform team has created 40 permission sets and finds maintaining them unsustainable.

What should the solutions architect recommend?

- ☐ A Consolidate to one permission set using ABAC, matching a team attribute passed as a session tag against resource tags
- ☐ B Give each team its own AWS account and one shared administrator permission set
- ☐ C Replace the permission sets with an SCP per team
- ☐ D Automate permission set creation with CloudFormation StackSets

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A** One permission set with ABAC
The team attribute arrives as a session tag and is compared against the resource tag. A new team needs no AWS change at all.
- B** An account per team
Defensible in general, and a large restructuring that the scenario did not ask for. It also does not scale better when a team needs two environments.
- C** An SCP per team
SCPs are account-wide ceilings. They cannot vary by user within a shared account, which is exactly the requirement here.
- D** Automate the 40
Makes the sprawl faster to create rather than smaller. Forty permission sets still have to be reviewed, audited and eventually deleted.

THE SIGNAL

Many groups needing the same shape of access with a different scope is the ABAC signature. It replaces N policies with one.

A bank runs Active Directory on-premises. Regulation forbids replicating or storing employee directory data outside its own data centres. It wants to deploy Amazon WorkSpaces in a single AWS account so staff can sign in with existing credentials.

A high-bandwidth Direct Connect link to the data centre already exists.

Which directory option should the architect choose?

- ☐ A AWS Managed Microsoft AD with a two-way forest trust to on-premises
- ☐ B AD Connector pointing at the on-premises directory
- ☐ C Simple AD with users imported from the on-premises directory
- ☐ D An Amazon Cognito user pool federated to Active Directory

◆ PAUSE AND DECIDE

Which directory option should the architect choose?

- A** Managed Microsoft AD with a trust
A trust avoids copying accounts, but the service still holds directory objects in AWS. It is also more service than a single account needs.
- B** AD Connector
A proxy that caches nothing. Authentication is forwarded on-premises, so no directory data resides in AWS, and WorkSpaces is supported.
- C** Simple AD with an import
Importing is replicating, which the regulation forbids. Simple AD also cannot trust an existing forest, and is closed to new customers.
- D** Cognito user pool
Cognito is for application users. WorkSpaces needs a directory, and bank staff are workforce rather than customers.

THE SIGNAL

No directory data may leave the data centre is a phrase with exactly one answer. AD Connector is the only option that stores nothing.

The same bank now needs domain-joined EC2 instances, Amazon FSx for Windows File Server, and RDS for SQL Server across eleven AWS accounts. Staff must still authenticate with their existing on-premises credentials.

The architect proposes reusing the AD Connector from the WorkSpaces project.

What should the architect be told?

- ☐ A AD Connector cannot be shared across accounts; use AWS Managed Microsoft AD with a trust to on-premises
- ☐ B Deploy an AD Connector in each of the eleven accounts
- ☐ C AD Connector supports this once VPC peering is configured between the accounts
- ☐ D Replicate the on-premises directory into Simple AD and share that

◆ PAUSE AND DECIDE

What should the architect be told?

- A** Managed Microsoft AD with a trust
It can be shared across accounts, and a trust means credentials are still validated on-premises rather than copied.
- B** One AD Connector per account
Technically possible and operationally poor. Eleven connectors, eleven sets of credentials to maintain, and no shared domain across them.
- C** Peering fixes it
Peering is a network path. The limitation is a service one: AD Connector is not shareable and is not multi-VPC aware.
- D** Replicate into Simple AD
Replication is still forbidden, Simple AD cannot trust a forest, and it is closed to new customers.

THE SIGNAL

One constraint changed from scenario three: eleven accounts instead of one. That alone flips the answer.

A media company is launching a mobile app expecting three million users. People will sign up with email or Google, and upload video directly from the device to Amazon S3, into a prefix belonging only to them.

The team's first design routes every upload through an EC2 fleet holding one IAM role.

What should the solutions architect recommend instead?

- A IAM Identity Center with a permission set for application users
- B A Cognito user pool for sign-in, and an identity pool issuing scoped credentials for direct upload
- C A Cognito user pool alone, with the app calling S3 using an embedded access key
- D Keep the EC2 proxy but add an Application Load Balancer for scale

◆ PAUSE AND DECIDE

What should the solutions architect recommend instead?

A Identity Center

Built for a workforce. Nobody assigns permission sets to three million consumers, and they have no business in an AWS account.

C User pool with an embedded key

An access key shipped inside a mobile app is extractable by anyone who downloads it. This is the worst option in the list.

B User pool plus identity pool

The user pool handles email and Google sign-in. The identity pool exchanges the token for credentials scoped to that user's own prefix.

D Scale the proxy

Pays compute and data transfer to relay video that could go straight to S3, and one shared role cannot isolate three million prefixes.

THE SIGNAL

Application users needing to touch an AWS service directly is the identity pool signature. The user pool alone only proves who they are.

A data platform lets 400 analysts query a lake through Amazon Athena and Amazon Redshift. The query tool assumes a single shared IAM role on their behalf.

Compliance has rejected the design: CloudTrail records the shared role for every query, so it is impossible to prove which analyst read which dataset.

What should the solutions architect implement?

- ☐ A Create 400 IAM roles, one per analyst, and have the tool assume the right one
- ☐ B Enable trusted identity propagation through IAM Identity Center
- ☐ C Turn on CloudTrail data events for the S3 buckets behind the lake
- ☐ D Pass the analyst's username as a session tag on the shared role

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

400 individual roles

Solves attribution and creates 400 roles to maintain, plus per-dataset policies in each. The scale problem ABAC and propagation exist to remove.
- B

Trusted identity propagation

The user identity reaches Athena and Redshift, so authorisation runs against the person and CloudTrail records them.
- C

S3 data events

Records more calls made by the same shared role. More volume, identical attribution problem, and a noticeable bill.
- D

Session tag the username

The closest miss. It does surface the name in CloudTrail, but it is asserted by the tool rather than proven, so it is not evidence.

THE SIGNAL

The audit trail names the role rather than the person, on an analytics service, is this feature's exact signature.

What to carry out of this module

- ◆ A permission set provisions a real IAM role. Module two's evaluation chain still applies to it.
- ◆ AD Connector stores nothing and cannot be shared. Managed Microsoft AD can be shared and holds trusts.
- ◆ Employees mean Identity Center. App users mean Cognito: user pool proves identity, identity pool grants AWS access.
- ◆ Same access shape, different scope, many groups means **ABAC**. Never one policy per team.

ON THE EXAM

Identify the humans first. Employee, application user, or service. Then the directory question usually answers itself.